DATHEON / APPLICATION SECURITY

Task 3 — Cryptographic Session Security Report

Datheon Application Security & API Pentesting Internship · 30 October–27 November 2026

Adil Firoz · Batch 01 · The Neotia University · B.Tech Computer Science and Engineering (Cybersecurity)

LOCAL SYNTHETIC-DATA TRAINING PORTFOLIO

Task 3 — Cryptographic Session Security Report

Adil Firoz · Datheon Application Security & API Pentesting Internship · Batch 01

The Neotia University · B.Tech Computer Science and Engineering (Cybersecurity)

Assessment type: Local session-security lab

Executive summary

The training app hashes passwords with scrypt, signs short-lived session tokens with HMAC-SHA256, stores tokens in HttpOnly/SameSite cookies, validates CSRF tokens on state-changing session routes, throttles repeated failed logins, and supports session rotation and revocation.

Scope and architecture

Two fictional accounts, a Node.js/Express API, Node crypto primitives, and a process-local development session store. No external identity provider or real user account is involved.

Implementation

The JWT expires after 15 minutes. A random session identifier and CSRF value are bound to an in-memory session entry; rotating changes the credential and invalidates the previous token. Login uses generic errors and per-IP failed-attempt throttling. Logout deletes the session and expires both cookies. The CSRF header must match the readable same-site CSRF cookie and active session value.

Cookies use HttpOnly, SameSite=Strict, and configurable Secure. Local HTTP sets Secure=false; production mode emits HSTS. A production deployment must use HTTPS and a shared session/rate-limit backend.

localStorage comparison

Tokens in localStorage are readable by page JavaScript and can be stolen by successful XSS. HttpOnly cookies prevent JavaScript from reading the session token, but browsers attach cookies automatically, so CSRF defenses, SameSite, origin checks, and safe state-changing method design remain important. Neither pattern removes the need to prevent XSS.

Test procedure and results

Tests check login, cookie attributes, session verification, CSRF rejection, token rotation, logout revocation, generic invalid-credential errors, and brute-force throttling. The generated PDF reports the actual Vitest JSON counts and result.

Limitations and conclusion

The process-local session store and throttler reset on restart and do not coordinate across instances. Use a managed shared store, key rotation, TLS, observability, and framework-reviewed JWT/session libraries for production. The implementation is a controlled teaching example, not a production authentication service.

References

- RFC 7519 — JSON Web Token (JWT).

- OWASP Session Management Cheat Sheet.
- OWASP Cross-Site Request Forgery Prevention Cheat Sheet.
- Node.js Crypto documentation.

Automated test execution

Vitest run: PASSED · 8/8 passed · 0 failed

Test case	RESULT	Duration
Task 3: cookie-based session security sets an HttpOnly, SameSite cookie and validates the session	PASSED	45 ms
Task 3: cookie-based session security requires CSRF validation and rotates then invalidates the prior token	PASSED	54 ms
Task 3: cookie-based session security returns a generic authentication error and applies brute-force throttling	PASSED	141 ms